

Primer Aviso Security & Governance

Security and Governance Note

Build: Primer Aviso. Multi-agent first notice of loss for catastrophe surges.

This note records the security and governance controls applied to the reference implementation, the reasoning behind each, and its current status.

1. Human oversight
Control: Every case leaves the workflow in a pending-review state, and the system never sends a confirmation on its own.
Rationale: A handler must review, edit if needed, and approve before the claimant receives any confirmation number.
Status: Implemented.
2. No autonomous coverage, payment, or legal decisions
Control: The system labels every listed coverage "subject to verification by a handler."
Rationale: It never confirms that a coverage will pay, sets a reserve, or authorises any action beyond registering the aviso.
Status: Implemented.
3. Deterministic safety response
Control: A keyword check plus a small, isolated model check run before any data collection to detect a life-threatening emergency.
Rationale: If either detects a life-threatening emergency, the workflow immediately shows Colombia's emergency line (123) and pauses, with no forms and no data questions in that turn.
Status: Implemented.
4. Deterministic triage, not model opinion
Control: Priority (P1 to P3) and related-report detection are both computed entirely in code, from fixed rules over extracted fields.
Rationale: The model has no path to influence which cases a handler sees first.
Status: Implemented.
5. Explicit "not contracted" labelling
Control: The system states plainly when an expected coverage (such as earthquake cover) is not contracted, rather than omitting it.
Rationale: This protects both the claimant, who deserves a clear answer, and the insurer, against any suggestion that the system hid a gap in coverage.
Status: Implemented.
6. Bereavement handling
Control: When a death is reported, the system does not request sensitive documents (such as a death certificate) in the same conversation. It offers brief condolences, mentions the Registro Único de Seguros as information, and routes to a person.
Rationale: No automated system decides how or when to ask a grieving family for paperwork.
Status: Implemented.

7. Data residency

Control: Model calls run against gpt-5-mini deployed in Sweden Central under the Data Zone Standard EU option.

Rationale: This ensures keeping processing within the EU data zone.

Status: Implemented.

8. Synthetic data handling

Control: All household, policy, and claimant data used in this build is synthetic, and photos are generated illustrations.

Rationale: This ensures they are not real photographs of any person or location.

Status: Implemented.

9. Deliberately out of scope for this reference implementation

The following are not implemented, by scope:

System integration: no integration with a real policy administration system yet (household lookup is a local file).

Live monitoring: no monitoring dashboard for failure rate during a live surge.

Language support: single-language support (Colombian Spanish only).